



black hat[®] EUROPE 2025

DECEMBER 8-11, 2025

EXCEL LONDON / UNITED KINGDOM

AI VS. AI

Building Resilient Enterprises in the Age of Autonomous Threats



DINIS CRUZ

GenAI Entrepreneur & Former CISO Akeia.ai / The
Cyber Boardroom / MyFeeds.ai



THE PERFECT STORM

Why This Moment Is Different

SECURITY'S FOUR PILLARS - ALL BROKEN

ENGINEERING & TECHNOLOGY

We know how to build secure systems - we don't do it at scale

BUSINESS PROCESSES

Security is an afterthought, not embedded in decisions

FUNDING & FOCUS

NFRs chronically underfunded - features always win

RISK MANAGEMENT

Spreadsheets and heat maps disconnected from technical reality

Systems are insecure not because engineers are stupid, but because the ENVIRONMENT forces corner-cutting. All four pillars must be aligned.

WE'VE BEEN GETTING AWAY WITH IT

AWS

Timing bug wiped out a global database

AZURE

Config inconsistency silently propagated, then 'detonated' worldwide

CLOUDFLARE

Routine config change crashed bot defense, halted traffic

CROWDSTRIKE

8.5 million Windows systems bricked by a faulty update

These weren't sophisticated attacks - they were minor glitches that cascaded. Now imagine if they were deliberate, coordinated attacks.



THE NEW INSIDERS

Autonomous Agents as Threat Actors

THREE CATEGORIES OF AI-DRIVEN THREATS

MALICIOUS AI AGENTS

Fully autonomous malware that learns, adapts, and persists

COMPROMISED BENIGN AGENTS

Your AI bots hijacked via prompt injection - operating with legitimate access, now working for the adversary

UNINTENTIONALLY HARMFUL AGENTS

The paperclip maximizer scenario - dangerously efficient in ways we didn't anticipate

Prompt injection remains unsolved - any AI taking untrusted input can be subverted.

HUMAN INSIDERS VS. AI AGENTS

Human Insiders

- Natural limitations on skill and time
- Rarely had maximal destructive intent
- Fatigue, fear of detection, single-threaded
- Contained failures - couldn't scale chaos

AI Agents

- Tireless, infinite patience
- Machine-speed adaptation and iteration
- Finds alternate paths when blocked
- No moral compass unless explicitly constrained

WHY ENTERPRISES AREN'T READY

Fragile by Design

FRAGILE BY DEFAULT

- Technical Debt Crisis
 - ~40% of IT asset value is technical debt (McKinsey)
 - Systems running 'hot' with minimal safety margins
- Hidden Interdependencies
 - Internet = circular dependency machine
 - Identity, DNS, cloud, CDN - one failure cascades globally
- No Visibility, No Recovery
 - Only ~54% have documented DR plans - fewer actually test them
 - Average breach detection: 9 months of dwell time
- No Version Control for Data
 - Code has Git. Databases? Configs? Often nothing.
 - If an AI corrupts records, can you rewind?

THE DEFENDER'S EDGE

AI as Force Multiplier, Not Black Box

ATTACKERS ALWAYS MAKE MISTAKES

- The '100% Prevention' Myth
 - You cannot patch everything, eliminate every gap
 - And you don't have to
- Every Attack Has 5-10 Missteps
 - Unusual logins, wrong processes, odd data movement
 - Attackers lack perfect insider knowledge - they wander, they probe
- Your Job: Catch the Mistakes
 - Before they reach the crown jewels
 - Whether it's an external attacker OR your own AI spiraling

SECURITY'S ASYMMETRIC ADVANTAGE

- Unique Enterprise-Wide Vantage Point
 - Access to every system, every data flow
 - One of few functions focused on business SURVIVAL, not narrow objectives
- You Know What 'Good' Looks Like
 - You define the baseline - attackers must deviate from it
 - The moment something acts outside normal, you catch it
- Home Court Advantage
 - Attackers wander chasing dead ends, making noise
 - You know the terrain - use it

THE MECHANISM: KNOWLEDGE GRAPHS

- Build a Digital Twin of Your Enterprise
 - Systems, data flows, identities, dependencies - all connected
 - Not static docs - a living, queryable model
- Semantic Graphs Link Everything
 - Each team's data model connects to the whole
 - Query: 'What breaks if System X goes down?' - instant answer
- AI Builds and Maintains the Graph
 - LLMs digest docs, configs, logs into structure
 - Humans make decisions, AI updates the map continuously

RADICAL SIMPLIFICATION

The Answer Isn't More Complexity

ASSUME COMPROMISE, CONTAIN BLAST RADIUS

- Strong Segmentation Inside
 - Crown-jewel systems walled off with strict controls
 - One-way isolation for legacy components that can't be fixed
- Graceful Degradation = Victory
 - Parts may fail, but they fail SAFELY
 - No cascade into total enterprise collapse
- Hardened Boundaries Around What Can't Be Fixed
 - API throttles for fragile older systems
 - Circuit breakers that halt abnormal transactions automatically

VERSION CONTROL EVERYTHING

- Code Has Git. What About Data?
 - If an AI corrupts your database, can you rewind?
 - Most orgs: No version history, no audit trail, no rollback
- Immutable Logs, Append-Only Where Possible
 - Every change recorded and reversible
 - Tampering becomes evident because history can't be rewritten
- Consider File System as Database
 - Simpler architecture = smaller attack surface
 - Standard backup/versioning tools work out of the box

IDENTITY GRAPHS: LEAST PRIVILEGE AT SCALE

- Map Every Identity and Permission
 - Users, services, AI agents - all in one graph
 - Query: 'If this account is compromised, what can it reach?'
- Just-in-Time, Just-Enough Access
 - Privileges that EXPIRE, not persist
 - Admin rights only when explicitly unlocked, auto-revoke after
- Shrink the Blast Radius
 - One compromised account $\neq$ full breach
 - Attacker hits walls immediately - can't pivot everywhere

FUND NFRS AT UNPRECEDENTED SCALE

- Comprehensive backup and restore drills - actually TEST them
- Chaos engineering beyond normal peaks - AI doesn't respect office hours
- Instrumentation everywhere for real-time visibility
- Consolidate overly complex workflows - fewer moving parts = fewer failure points
- Demand robustness from vendors - the market doesn't currently punish fragility



ENABLING INNOVATION

Security as Enabler, Not Gatekeeper

VIBE CODING: THE NEW SPREADSHEETS

- Creating Software Is Now Trivially Easy
 - Non-engineers building apps via AI prompts
 - If the software doesn't exist, they will will it into existence over coffee
- Same Pattern as Excel - On Steroids
 - Solves immediate problem brilliantly
 - Becomes mission-critical overnight
 - Zero security, testing, or governance built in
- Shadow AI Is Already Here
 - Employees pasting sensitive data into ChatGPT daily
 - Department-level AI tools running under IT's radar

DON'T BECOME THE DEPARTMENT OF 'NO'

- The Horse Has Bolted
 - Employees will use AI regardless of policy
 - Shadow-IT AI is far worse than governed AI
- Security as Enabler and Guide
 - Provide vetted platforms and clear guidelines
 - Build safe internal AI services before they run to ChatGPT
- Create Handoff Pathways
 - Pair business 'vibe coders' with engineering buddies
 - When a prototype gets traction, help industrialize it safely



THE PATH FORWARD

From Reactive Firefighting to Proactive Containment

CALL TO ACTION

- Build your digital twin now
 - Knowledge graphs of your enterprise - don't wait for a crisis
- Invest in detection over prevention
 - Catch the 5-10 mistakes attackers will make
- Simplify ruthlessly
 - Every agent you add is attack surface - earn its place
- Version control EVERYTHING
 - Data, configs, permissions - if you can't rewind, you can't recover
- Enable, don't block

QUESTIONS?

@DinisCruz | The Cyber Boardroom | Akeia.ai